第四届开放原子大赛 · 2026 开源行业解决方案创新赛（赛道一）

BILEI WAF · 壁垒WAF

规则+ AI 的双通道检测架构，反代代理架构 · 毫秒级拦截 · 全流量可视化

99.903%	1,087 条	8 大类	5,759
综合准确率（auto 模式）	内置检测规则	OWASP 攻击覆盖	HTTP 处理 QPS

参赛单位：内蒙古勤加软件有限公司

CONTENTS

01 定位 · 架构 · 核心指标

02 应用场景

03 实时攻击模拟 · 拦截验证 · 功能总览

04 全球攻击态势 · 实时攻击流 · 趋势分析

05 blazehttp 全量回放 · 三模式对比 · 基线对比

06 登录 · 大屏 · 日志 · 站点 · 证书 · 规则 · 端口

反向代理架构 · 规则引擎 + AI 双引擎检测

专业、稳定的 Web 应用防火墙一体化应用安全防护方案

对网站与 App 业务流量进行恶意特征识别与防护，清洗过滤后将正常、安全的流量返回给源站，避免服务器被恶意入侵，保障业务安全与数据安全。

99.90%	8 类	毫秒级	C 语言
blazehttp 测评综合准确率	Web 攻击检测规则引擎	规则预筛 + AI 双通道检测	多线程高性能内核

· 规则 + AI 双通道联级 · 工程化 AI · 主动防护闭环 · 全链路可视化 · 低门槛部署

```
[ 壁垒WAF BiLeiWAF bileiwaf.com ~]# free -m
              total        used        free
Mem:           1963         661         385
```

壁垒WAF BiLeiWAF

· 规则 + AI 双通道联级

1,087 条内置规则与 AI 集成模型（基于规则库蒸馏训练）联级复核，blazehttp 全量回放实测检出率 99.70%、误报率 0.09%、综合准确率 99.903%，吞吐 5,759 QPS

· 工程化 AI

影子模式灰度、fail-safe 规则兜底、AILEARN 护栏自主学习（学习产物为可审计规则文本，铸造前经白名单全量评估防误报）

· 主动防护闭环

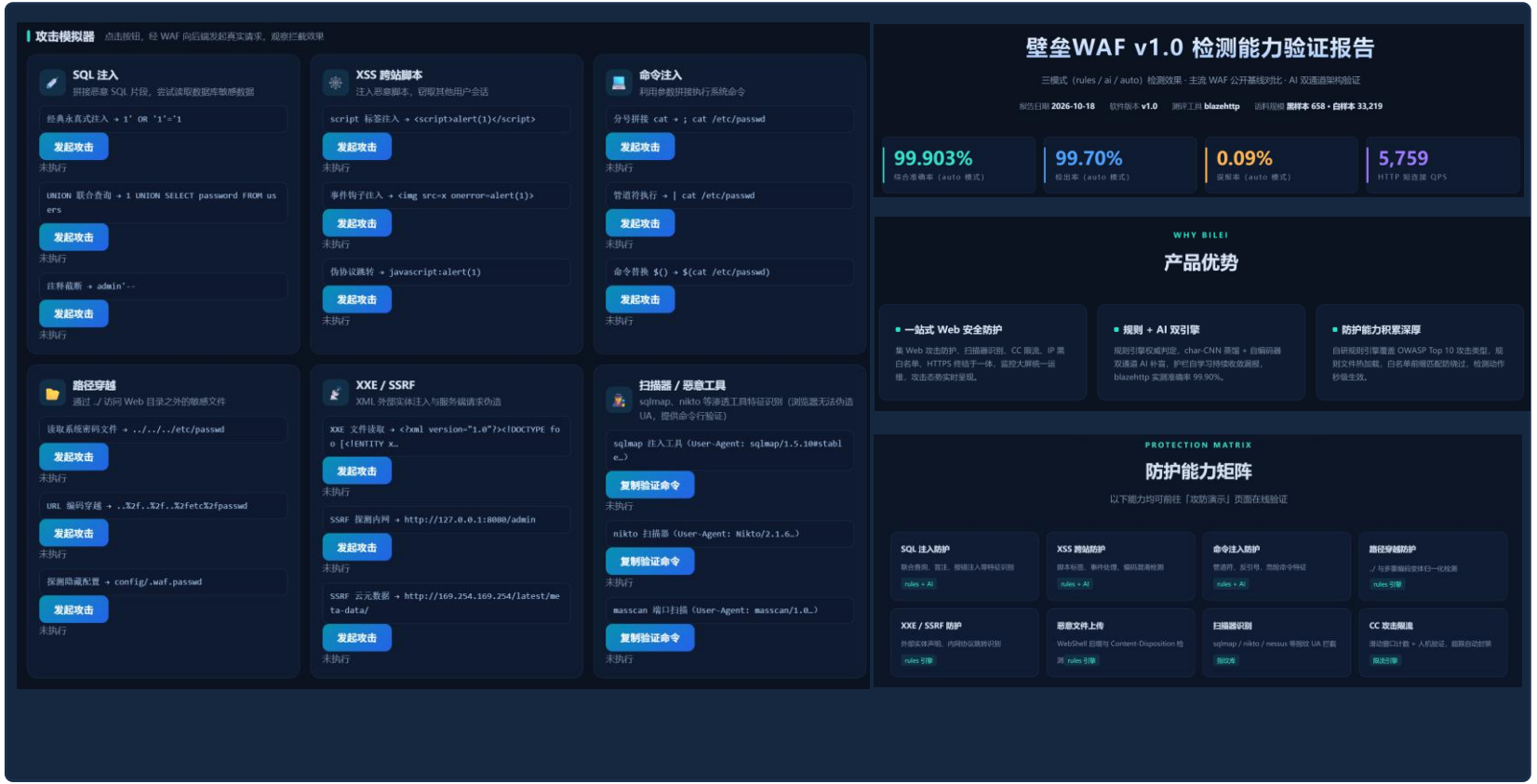
CC 频率检测 + 人机验证 + IP 自动黑名单（动态拉黑、到期自动解封），黑白名单白名单优先豁免

· 全链路可视化

实时监控大屏（今日攻击/本月拦截/实时 QPS/全球态势）、攻防演示页一键实测、攻击日志多维检索，日志轮转后统计不断档

· 低门槛部署

2 GB 内存低配服务器即可承载，支持 systemd 托管、RPM/二进制发行包、Let's Encrypt自动签发续期，已在 dbask.cn、bileiwaf.com 等多个生产站点长期稳定运行


攻击模拟器
点击按钮，经 WAF 向后端发起真实请求，观察拦截效果
SQL 注入
拼接恶意 SQL 片段，尝试读取数据库敏感数据
经典永真式注入 → 1' OR '1'='1
发起攻击
未执行
UNION 联合查询 → 1 UNION SELECT password FROM users
发起攻击
未执行
注释截断 → admin'--
发起攻击
未执行
XSS 跨站脚本
注入恶意脚本，窃取其他用户会话
script 标签注入 → <script>alert(1)</script>
发起攻击
未执行
事件钩子注入 → <img src=x onerror=alert(1)>
发起攻击
未执行
伪协议跳转 → javascript:alert(1)
发起攻击
未执行
命令注入
利用参数拼接执行系统命令
分号拼接 cat → ; cat /etc/passwd
发起攻击
未执行
管道符执行 → | cat /etc/passwd
发起攻击
未执行
命令替换 $() → $(cat /etc/passwd)
发起攻击
未执行
路径穿越
通过 ../ 访问 Web 目录之外的敏感文件
读取系统密码文件 → ../../../etc/passwd
发起攻击
未执行
URL 编码穿越 → ..%2f..%2f..%2fetc%2fpasswd
发起攻击
未执行
探测隐藏配置 → config/.waf.passwd
发起攻击
未执行
XXE / SSRF
XML 外部实体注入与服务端请求伪造
XXE 文件读取 → <?xml version="1.0"?><!DOCTYPE foo [<!ENTITY x…
发起攻击
未执行
SSRF 探测内网 → http://127.0.0.1:8080/admin
发起攻击
未执行
SSRF 云元数据 → http://169.254.169.254/latest/meta-data/
发起攻击
未执行
扫描器 / 恶意工具
sqlmap、nikto 等渗透工具特征识别（浏览器无法伪造 UA，提供命令行验证）
sqlmap 注入工具 (User-Agent: sqlmap/1.5.10#stable…)
复制验证命令
未执行
nikto 扫描器 (User-Agent: Nikto/2.1.6…)
复制验证命令
未执行
masscan 端口扫描 (User-Agent: masscan/1.0…)
复制验证命令
未执行
壁垒WAF v1.0 检测能力验证报告
三模式（rules / ai / auto）检测效果 · 主流 WAF 公开基线对比 · AI 双通道架构验证
报告日期 2026-10-18
软件版本 v1.0
测评工具 blazehttp
语料规模 黑样本 658 · 白样本 33,219
99.903%
综合准确率（auto 模式）
99.70%
检出率（auto 模式）
0.09%
误报率（auto 模式）
5,759
HTTP 短连接 QPS
WHY BILEI
产品优势
一站式 Web 安全防护
集 Web 攻击防护、扫描器识别、CC 限流、IP 黑白名单、HTTPS 终结于一体，监控大屏统一运维，攻击态势实时呈现。
规则 + AI 双引擎
规则引擎权威判定，char-CNN 蒸馏 + 自编码器双通道 AI 补盲，护栏自学习持续收敛漏报，blazehttp 实测准确率 99.90%。
防护能力积累深厚
自研规则引擎覆盖 OWASP Top 10 攻击类型，规则文件热加载，白名单前缀匹配防绕过，检测动作秒级生效。
PROTECTION MATRIX
防护能力矩阵
以下能力均可前往「攻防演示」页面在线验证
SQL 注入防护
联合查询、盲注、报错注入等特征识别
rules + AI
XSS 跨站防护
脚本标签、事件处理、编码混淆检测
rules + AI
命令注入防护
管道符、反引号、危险命令特征
rules + AI
路径穿越防护
../ 与多重编码穿越归一化检测
rules 引擎
XXE / SSRF 防护
外部实体声明、内网协议跳转识别
rules 引擎
恶意文件上传
WebShell 后缀与 Content-Disposition 检测
rules 引擎
扫描器识别
sqlmap / nikto / nessus 等指纹 UA 拦截
指纹库
CC 攻击限流
滑动窗口计数 + 人机验证，超限自动封禁
限流引擎


壁垒WAF v1.0 检测能力验证报告
三模式（rules / ai / auto）检测效果 · 主流 WAF 公开基线对比 · AI 双通道架构验证
报告日期 2026-10-18 软件版本 v1.0 测评工具 blazehttp 语料规模 黑样本 658 · 白样本 33,219
99.903%
综合准确率（auto 模式）
99.70%
检出率（auto 模式）
0.09%
误报率（auto 模式）
5,759
HTTP 短连接 QPS
BLAZEHTTP
目标网站 https://dbask.cn
工作线程 10
其他配置
运行
总样本：33877 正常样本：33219 恶意样本：658
总请求：33877 请求成功：33875 请求出错：2
检出率：99.70% 正确拦截：656 漏报放行：2
误报率：0.09% 正确放行：33186 误报拦截：31
准确率：99.90%（正确拦截+正确放行）/ 总样本
平均耗时：173.27毫秒
LAZEHTTP
目标网站 http://192.168.81.128
工作线程 10
其他配置
运行
总样本：33877 正常样本：33219 恶意样本：658
总请求：33877 请求成功：33877 请求出错：0
检出率：99.70% 正确拦截：656 漏报放行：2
误报率：0.09% 正确放行：33188 误报拦截：31
准确率：99.90%（正确拦截+正确放行）/ 总样本
平均耗时：49.23毫秒
实测结果


壁垒WAF v1.0 检测能力验证报告
三模式（rules / ai / auto）检测效果 · 主流 WAF 公开基线对比 · AI 双通道架构验证
报告日期 2026-10-18 软件版本 v1.0 测评工具 blazehttp 语料规模 黑样本 658 · 白样本 33,219
99.903%
综合准确率（auto 模式）
99.70%
检出率（auto 模式）
0.09%
误报率（auto 模式）
5,759
HTTP 短连接 QPS
BLAZEHTTP
目标网站
http://192.168.81.128
工作线程
10
其他配置
运行
总样本：33877
正常样本：33219
恶意样本：658
总请求：33877
请求成功：33877
请求出错：0
检出率：100.00%
正确拦截：658
漏报放行：0
误报率：99.59%
正确放行：137
误报拦截：33082
准确率：2.35%（正确拦截+正确放行）/ 总样本
平均耗时：31.29毫秒
BLAZEHTTP
目标网站
https://bileiwaf.com
工作线程
10
其他配置
运行
总样本：33877
正常样本：33219
恶意样本：658
总请求：33877
请求成功：33876
请求出错：1
检出率：100.00%
正确拦截：658
漏报放行：0
误报率：97.58%
正确放行：803
误报拦截：32415
准确率：4.31%（正确拦截+正确放行）/ 总样本
平均耗时：234.61毫秒

CC防御触发效果

SCENARIOS

应用场景

Web 应用上线必备安全能力

为网站、H5、APP、小程序提供 0day 漏洞自动防护，无需人工打补丁，有效降低入侵、挂马、篡改、数据泄露风险。

多站点统一防护

单实例接入多个业务站点，按域名独立回源、独立策略，适合企业官网群、业务中台统一安全收口。

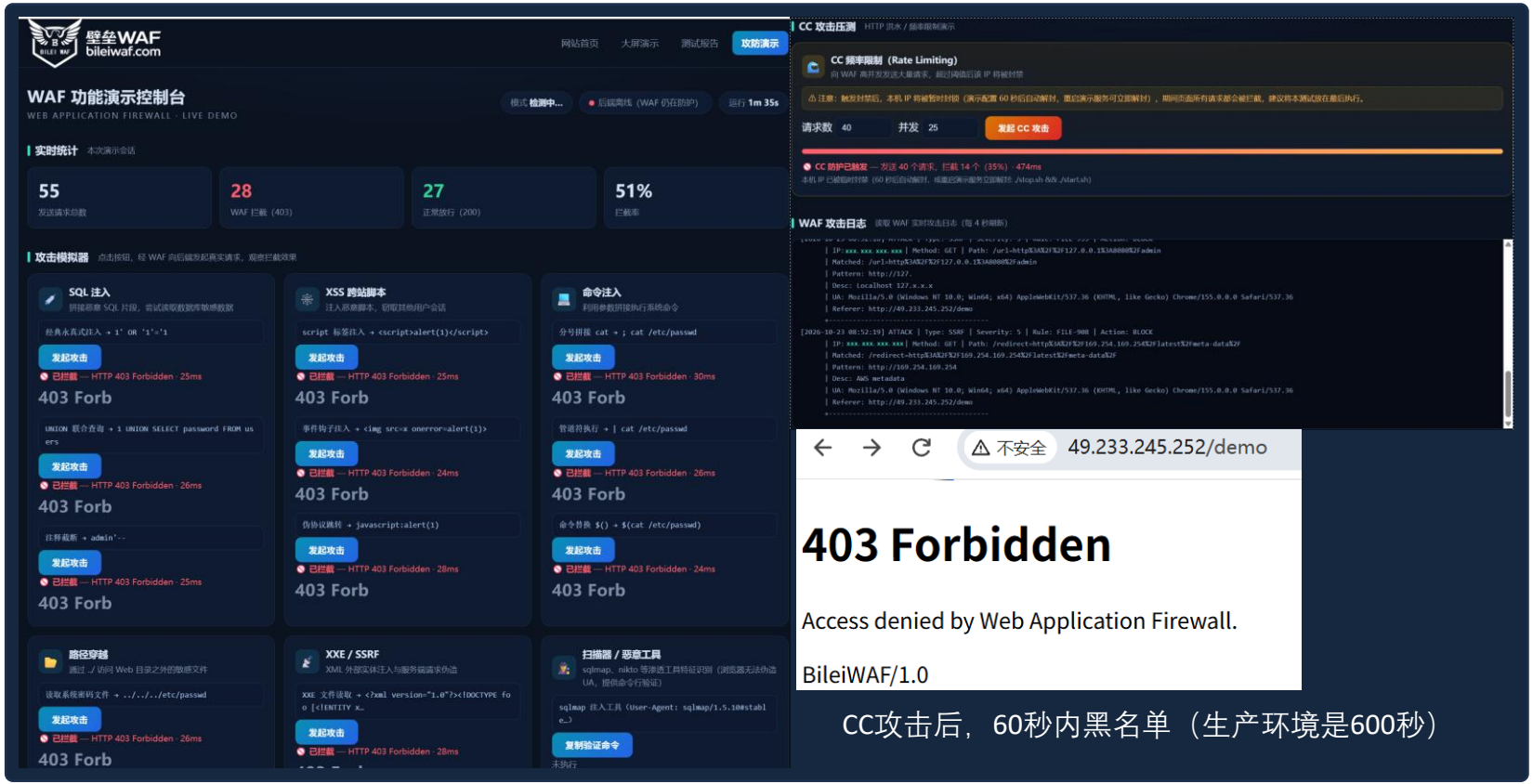
防爬虫防薅羊毛

扫描器指纹识别 + CC 限流双引擎，拦截自动化工具批量请求，保障营销活动与接口资源不被滥用。

安全合规建设

攻击防护、访问控制、审计日志为等级保护等合规认证提供必备能力项，安全报表支撑攻防复盘与溯源分析。

浏览器一键发起真实攻击载荷，WAF 拦截效果实时可见（403 拦截 / 200 放行）



CC攻击后，60秒内黑名单（生产环境是600秒）

tail -200 waf-attack.log



(KHTML, like Gecko) Chrome/155.0.0.0 Safari/537.36

| Action: BLOCK

(KHTML, like Gecko) Chrome/155.0.0.0 Safari/537.36

| Action: BLOCK

(KHTML, like Gecko) Chrome/155.0.0.0 Safari/537.36

| Action: BLOCK

| IP: xxx.xxx.xxx.xxx | Method: GET | Path: /demo/api/info
| UA: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/155.0.0.0 Safari/537.36
| Referer: http://49.233.245.252/demo
+----------

[2026-10-23 08:58:02] ATTACK | Type: SQL_INJECTION | Severity: 0 | Rule: | Action: BLOCK
| IP: xxx.xxx.xxx.xxx | Method: GET | Path: /demo/api/logs
| UA: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/155.0.0.0 Safari/537.36
| Referer: http://49.233.245.252/demo
+----------

功能总览

规则检测引擎
SQL 注入 / XSS / 命令注入 / 路径穿越 / XXE / SSRF 等多类攻击规则，POSIX 正则匹配，支持热加载

AI 智能检测
机器学习模型（孤立森林 / 随机森林 / 自编码器）与规则引擎混合双擎检测

CC 攻击防护
基于滑动时间窗的 IP 请求频率限制，超限自动封禁，支持白名单豁免

IP 黑白名单
IP 级访问控制，秒级生效，扫描器 / 爬虫 UA 特征识别

SSL/TLS 卸载
HTTPS 终结与证书管理，支持 Let's Encrypt 自动签发与续期

多站点防护
一台 WAF 同时代理防护多个域名，站点独立配置与日志

系统监控大屏
内置监控大屏：攻击态势总览、实时攻击事件、TOP 源与规则统计可视化

多维日志审计
攻击日志 / 访问日志 / 审计日志 / 错误日志，完整请求上下文记录

高性能架构
C 语言多线程 + 连接池 + epoll 事件驱动，低延迟反向代理

三种工作模式
学习模式（只告警）→ 检测模式（告警+记录）→ 阻断模式（实时拦截）

协议完整性校验
HTTP 协议合规、异常请求识别、API 防护、WebSocket 代理支持

GeoIP 地域封禁
按国家 / 地维度限制访问来源（内置 GeoIP 模块）

命令行验证示例

```
curl -i "https://bileiwaf.com/?id=1'%20OR%20'1'%3D'1"
curl -i "https://bileiwaf.com/?q=1%20UNION%20SELECT%20password%20FROM%20users"
curl -i "https://bileiwaf.com/?user=admin'--%20"
curl -i "https://bileiwaf.com/?name=%3Cscript%3Ealert(1)%3C%2Fscript%3E"
curl -i "https://bileiwaf.com/?x=%3Cimg%20src%3Dx%20onerror%3Dalert(1)%3E"
curl -i "https://bileiwaf.com/?url=javascript%3Aalert(1)"
curl -i "https://bileiwaf.com/?file=%3B%20cat%20%2Fetc%2Fpasswd"
curl -i "https://bileiwaf.com/?cmd=%7C%20cat%20%2Fetc%2Fpasswd"
```

```
curl -i "https://bileiwaf.com/? user=admin'--%20"

HTTP/1.1 403 Forbidden
Content-Length: 172
Connection: keep-alive
Keep-Alive: timeout=75, max=1000
```

04

攻击类型分布、威胁等级、攻击源 TOP5、24 小时趋势与实时攻击流一屏总览

全景(demo演示)



报告日期 **2026-10-18** 软件版本 **v1.0** 测评工具 **blazehttp** 语料规模 **黑样本 658 • 白样本 33,219**

99.903%	99.70%	0.09%	5,759
综合准确率（auto 模式）	检出率（auto 模式）	误报率（auto 模式）	HTTP 短连接 QPS

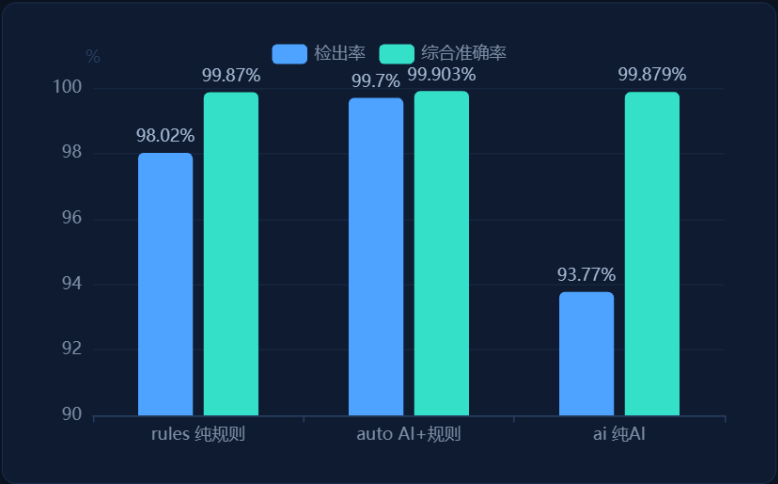
测评方法 METHODOLOGY

采用公开 WAF 测评工具 `blazehttp` 的真实 HTTP 语料全量回放：黑样本（攻击载荷）658 条、白样本（正常业务请求）33,219 条， 经 raw socket 以 30 线程并发发送至被测 WAF 监听端口。判定口径：黑样本未返回 `403` 记为漏报（FN）， 白样本被拦截为 `403` 记为误报（FP）。压测客户端 IP 已加入 WAF 白名单，避免 CC 防护干扰测评结果。

指标	计算方式	含义
检出率	(658 − FN) / 658	攻击样本被成功拦截的比例，越高越好
误报率	FP / 33,219	正常请求被错误拦截的比例，越低越好
综合准确率	1 − (FN + FP) / 33,877	全部样本判定正确的比例

三模式检测结果 THREE DETECTION MODES

v1.0 支持三种检测模式：`rules` 纯规则引擎（生产默认基线）、`ai` 纯 AI 集成（CNN+AE 双通道融合）、`auto` AI 先判 + 规则级联（推荐）。auto 模式下 AI 成功补拦 **11 个规则引擎漏检样本**，将漏报从 13 降至 2，且不引入新增误报。



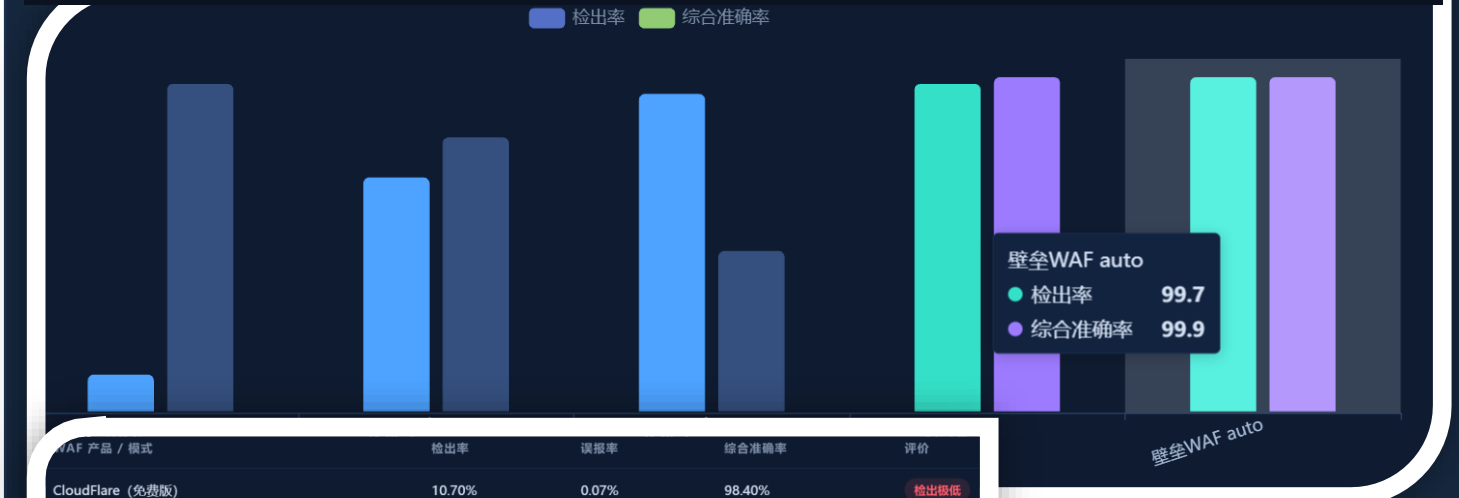
检测模式	漏报 FN	误报 FP	检出率	误报率	准确率
`rules` 纯规则	13	31	98.02%	0.09%	99.870%
`auto` AI+规则级联	**2**	31	**99.70%**	0.09%	**99.903%**
`ai` 纯 AI 集成	41	**0**	93.77%	**0.00%**	99.879%

纯 AI 模式误报为 0 但漏报偏高——蒸馏模型以规则为监督信号，定位为规则引擎的**增强补充**而非替代；`auto` 级联组合兼顾两者优势，为生产推荐配置。

相同样本基线下，检出率与综合准确率全面领先（ModSecurity PL4：94.61% / 48.34%）

主流 WAF 公开基线对比 BASELINE COMPARISON

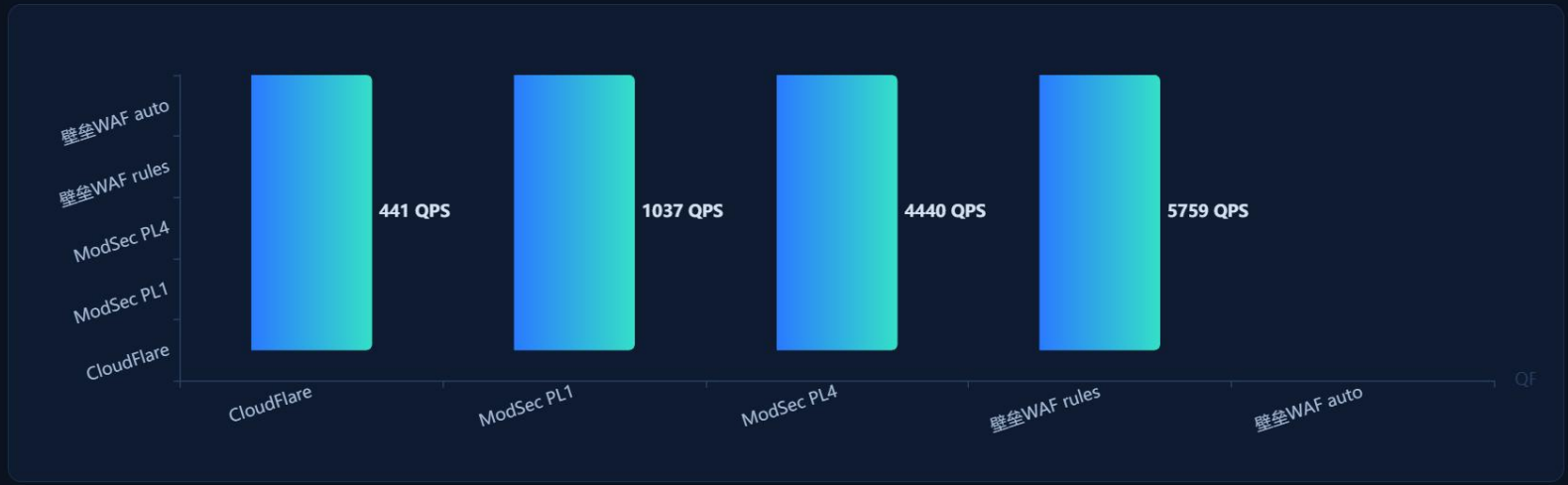
对比数据取自 blazehttp 官方 README 公开基线（相同样本集 33,669 条）与本次实测。壁垒WAF（auto 模式）在检出率、误报率、综合准确率三项指标上全面领先。



WAF 产品 / 模式	检出率	误报率	综合准确率	评价
CloudFlare（免费版）	10.70%	0.07%	98.40%	检出极低
ModSecurity（PL1 平衡）	69.74%	17.58%	82.20%	误报严重
ModSecurity（PL4 严格）	94.61%	52.46%	48.34%	误报过半
壁垒WAF v1.0（rules）	**98.02%**	**0.09%**	**99.87%**	三项领先
壁垒WAF v1.0（auto）	**99.70%**	**0.09%**	**99.90%**	最优

性能实测 PERFORMANCE

生产环境实测（C 语言多线程内核 + epoll + TLS Session Cache + 全路径 Keep-Alive）。 HTTPS 短连接受完整 TLS 握手限制属正常水平，前置 nginx 终结或启用 Keep-Alive 后可显著提升。



AI 双通道增强分析 AI DUAL-CHANNEL

AI 通道采用 char-CNN 蒸馏 + 自编码器（AE）自监督双通道融合架构：CNN 通道学习规则引擎的判定边界覆盖已知攻击， AE 通道仅学习白流量正常特征、对未见过的 0day 载荷给出异常分。融合校准（blazehttp 全量语料）结果 `w_cnn=1.00 / w_ae=0.00 / 阈值 0.9947` 。

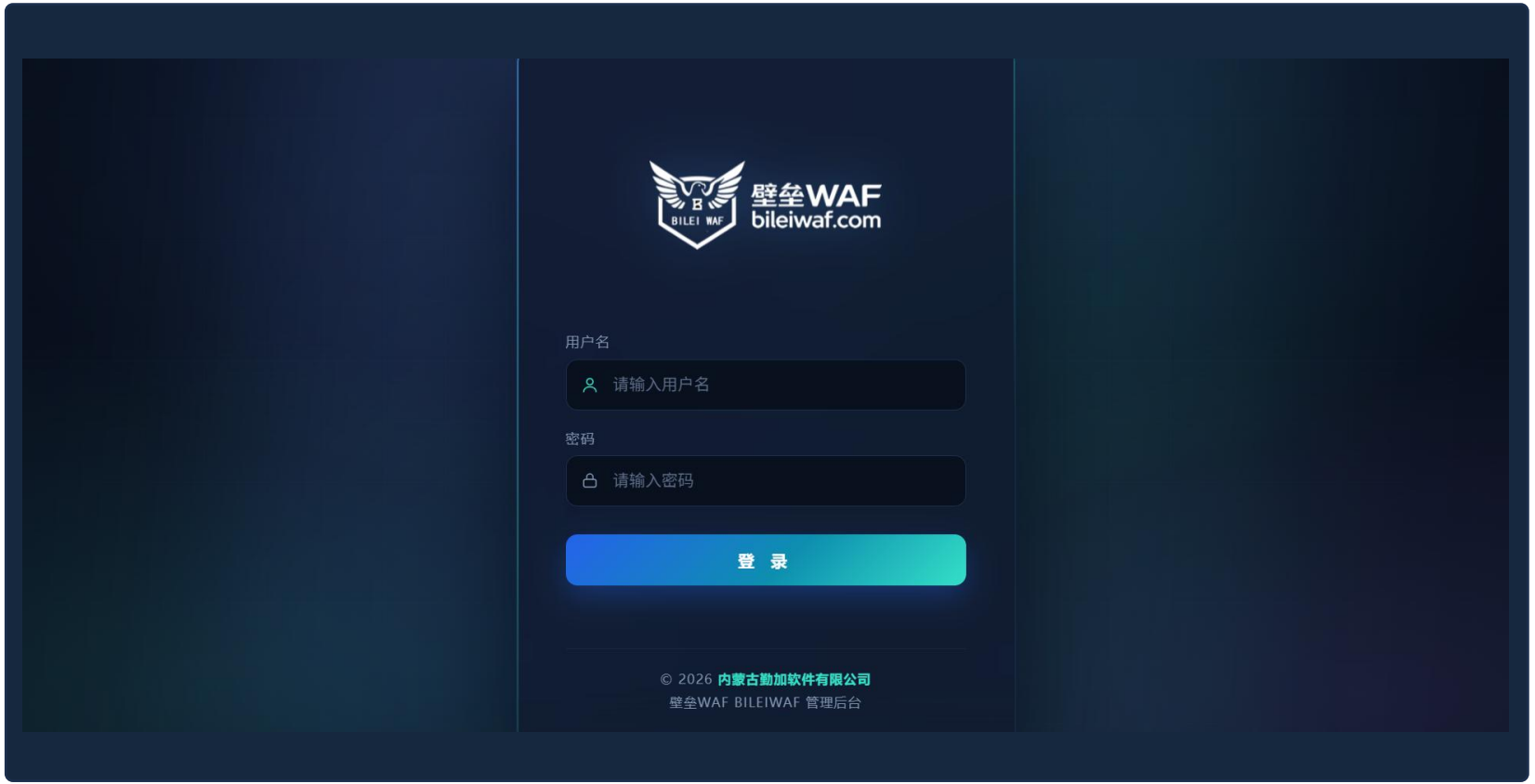
AI 补拦的 11 个规则漏检样本

攻击类型	数量
多层 Base64 编码混淆注入	3
Body 深度特征载荷	2
Apache Druid sampler RCE	1
Jenkins Groovy 控制台 RCE	1
Graphite 命令注入	1
CRLF 响应拆分注入	1
超长参数异常	1
异常 HTTP 方法	1

auto 模式残余漏报（2 个）

样本	原因分析
`POST /uc/feedback/api/v1/pc/feedback/add`	载荷与正常反馈接口报文高度同构，规则与 AI 置信均未达阈值
`POST /context.json`	JSON 结构伪装度高，特征与业务接口重叠

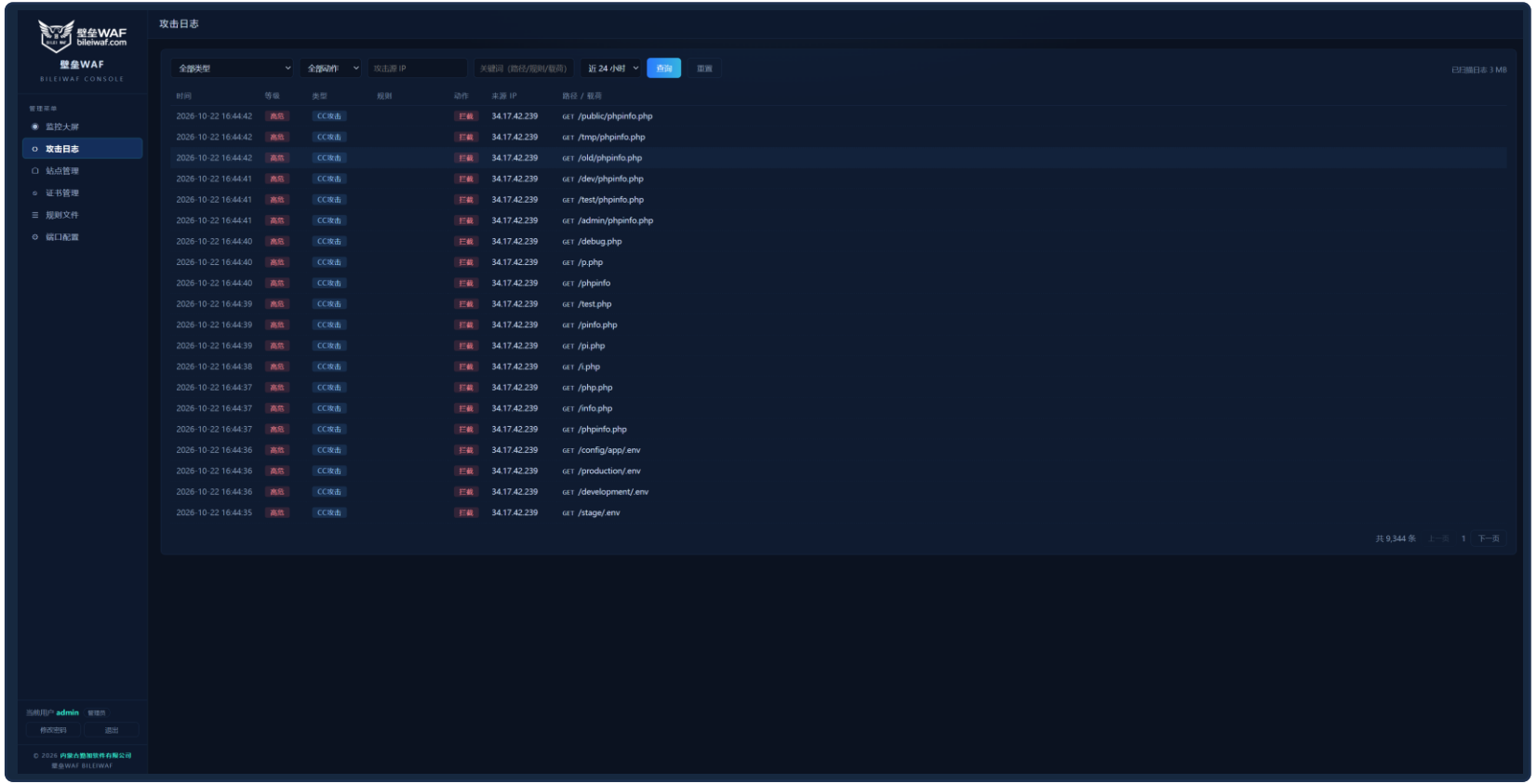
护栏自学习模块（waf_ai_guard）可持续将高分未拦截事件聚类铸造新规则（AILEARN），经全量白样本零误报校验后热加载生效，逐步收敛残余漏报。

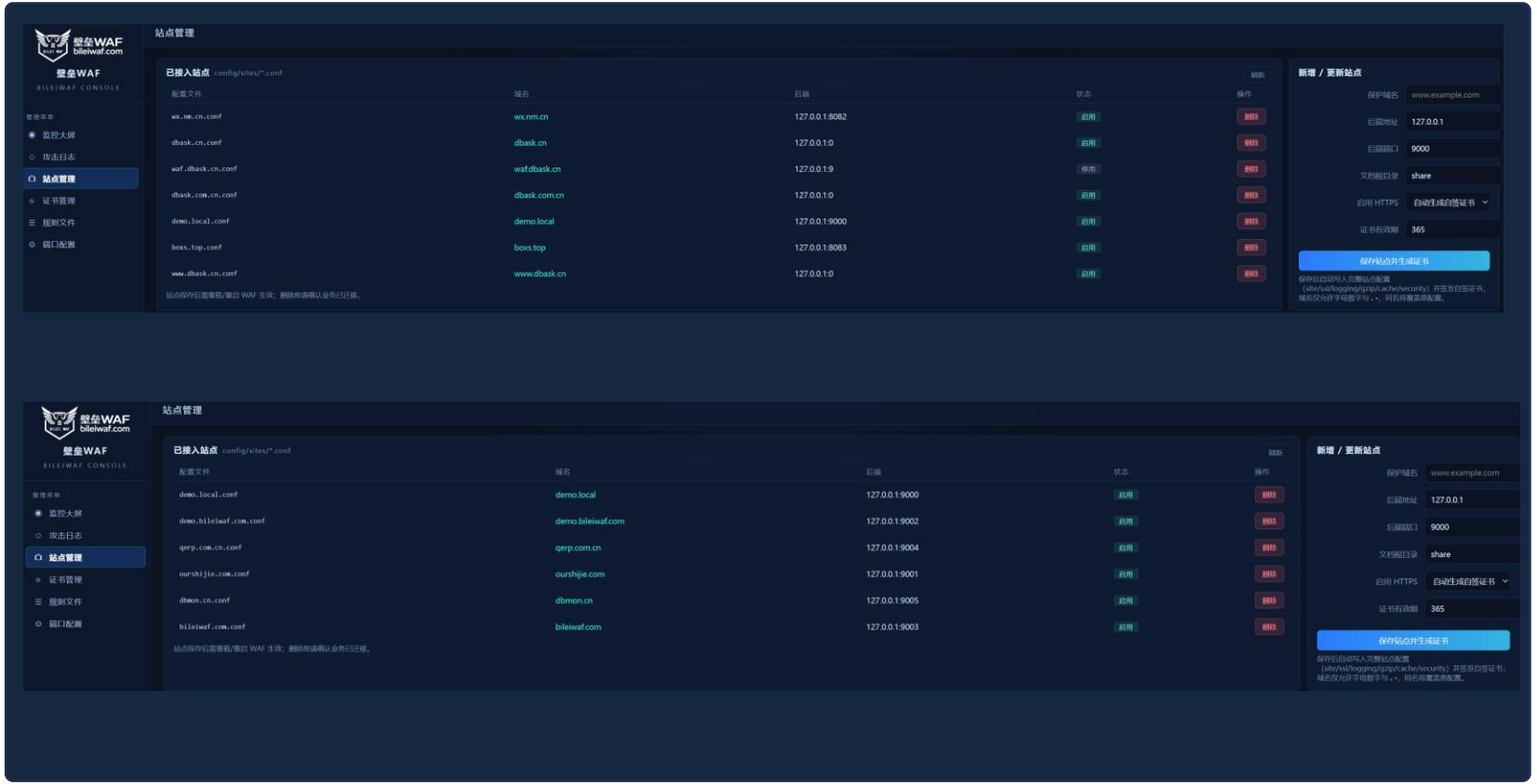

壁垒WAF
bileiwaf.com
用户名
请输入用户名
密码
请输入密码
登 录
© 2026 内蒙古勤加软件有限公司
壁垒WAF BILEIWAF 管理后台

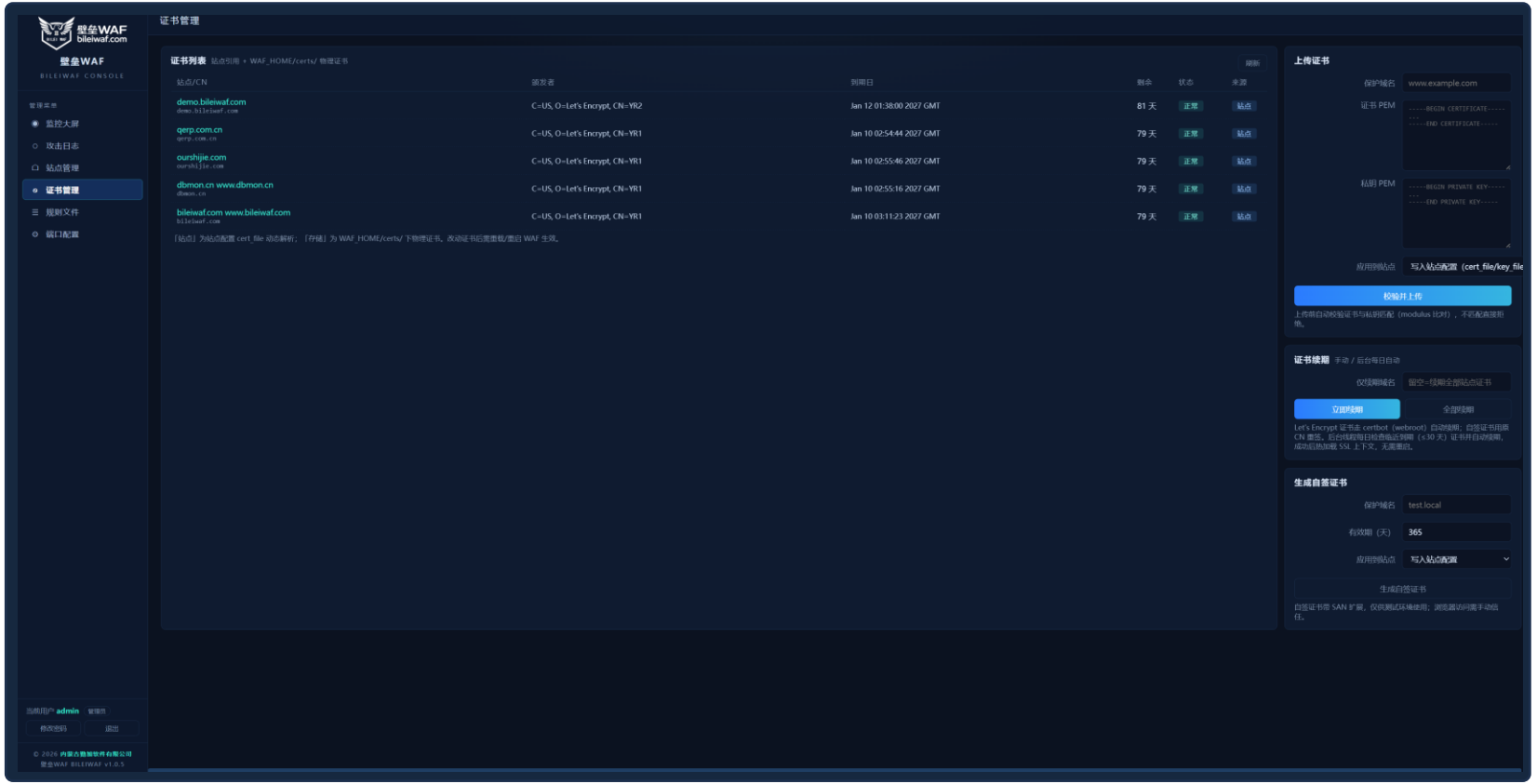
今日攻击 / 本月拦截 / 实时 QPS / 全球态势 / 命中规则 TOP5 管理侧全屏视图（真实数据）



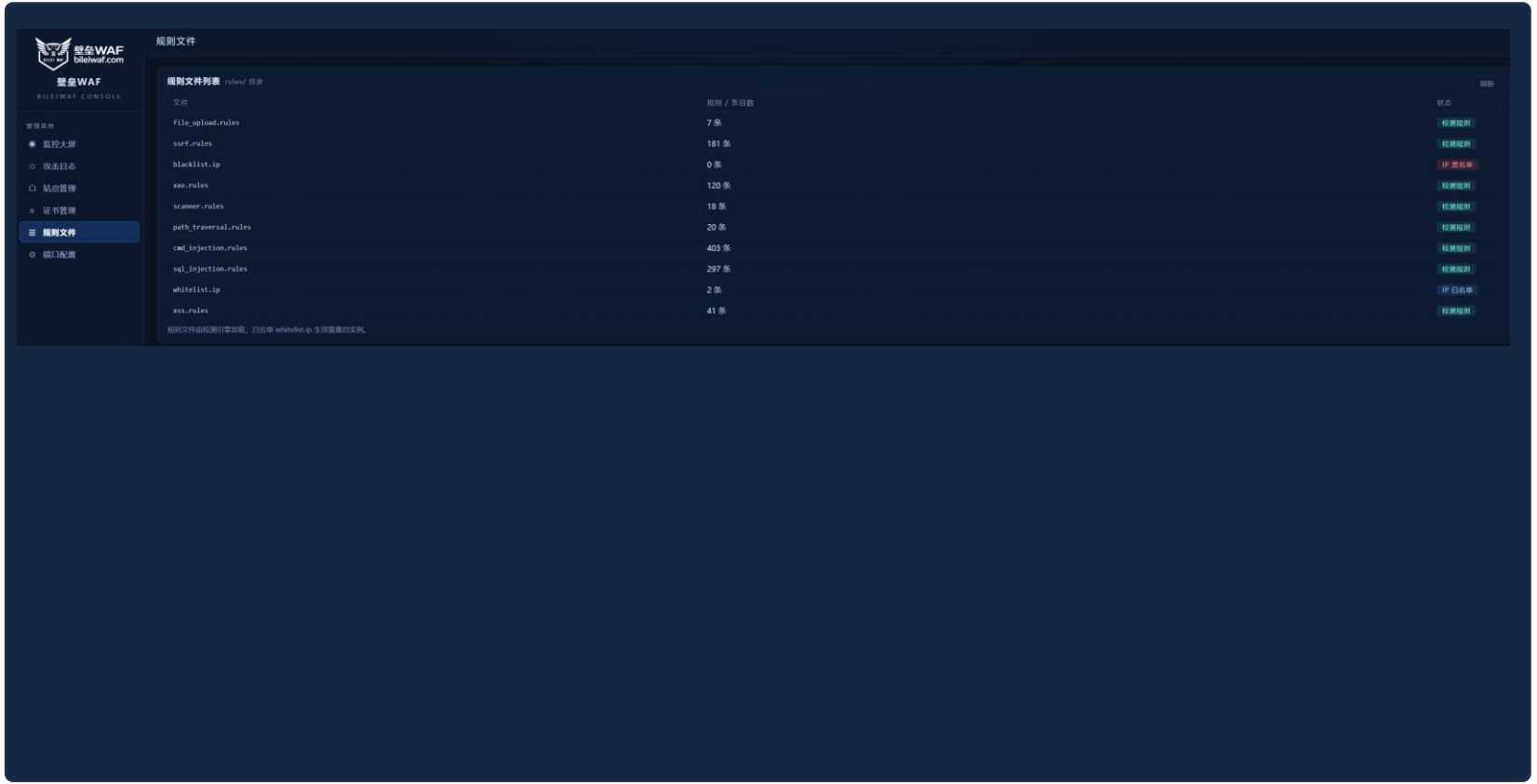
按类型 / 动作 / IP / 关键词 / 时间窗多维检索，攻击载荷与命中规则全量留痕



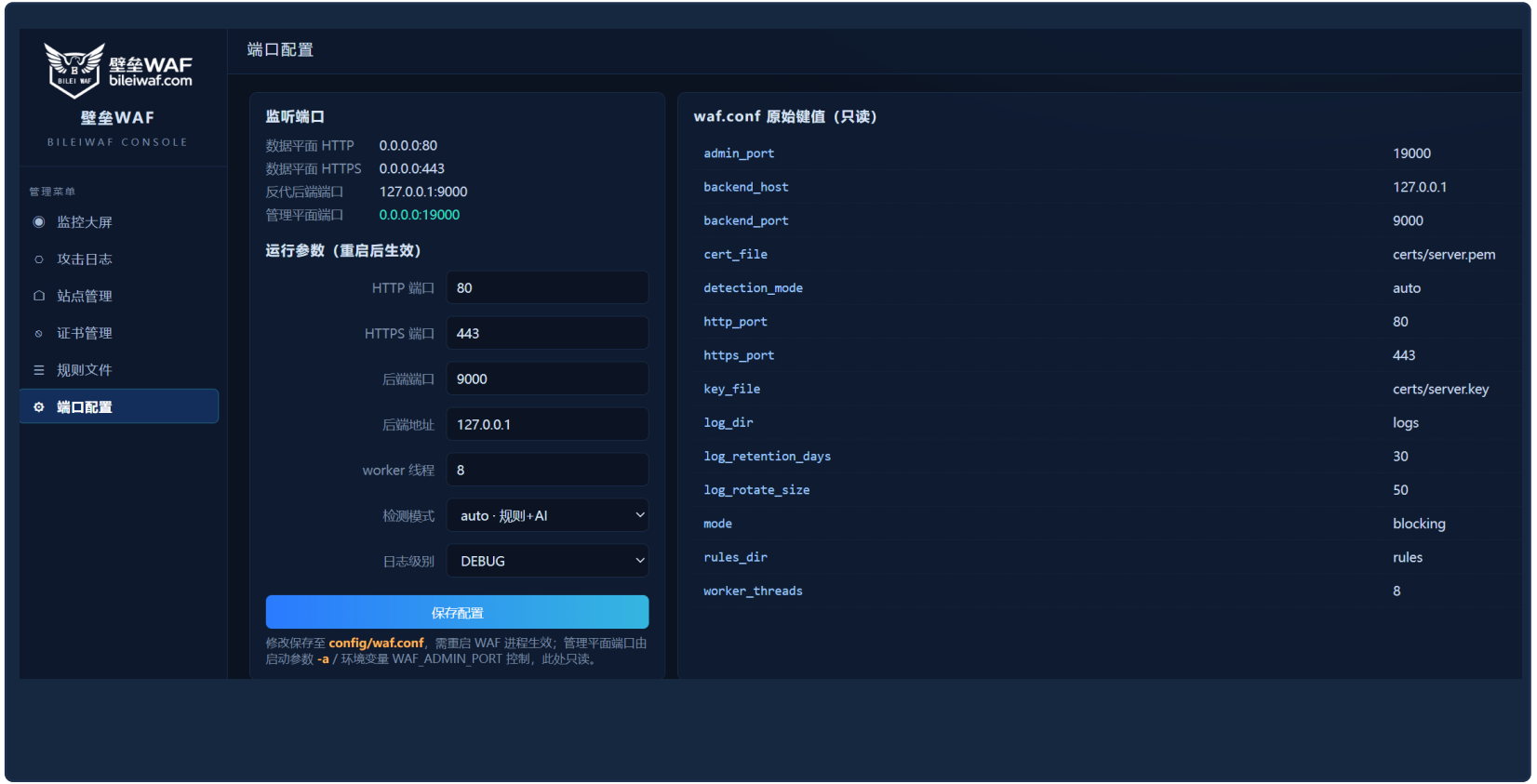

壁垒WAF
bileiwaf.com
壁垒WAF
BILEIWAF CONSOLE
监控大屏
攻击日志
站点管理
证书管理
规则文件
端口配置
站点管理
已接入站点 config/sites/*.conf
刷新
配置文件 域名 后端 状态 操作
wx.nm.cn.conf wx.nm.cn 127.0.0.1:8082 启用 删除
dbask.cn.conf dbask.cn 127.0.0.1:0 启用 删除
waf.dbask.cn.conf waf.dbask.cn 127.0.0.1:9 停用 删除
dbask.com.cn.conf dbask.com.cn 127.0.0.1:0 启用 删除
demo.local.conf demo.local 127.0.0.1:9000 启用 删除
boxs.top.conf boxs.top 127.0.0.1:8083 启用 删除
www.dbask.cn.conf www.dbask.cn 127.0.0.1:0 启用 删除
站点保存后需重载/重启 WAF 生效；删除前请确认业务已迁移。
新增 / 更新站点
保护域名 www.example.com
后端地址 127.0.0.1
后端端口 9000
文档根目录 share
启用 HTTPS 自动生成自签证书
证书有效期 365
保存站点并生成证书
保存后自动写入完整站点配置（site/ssl/logging/gzip/cache/security）并签发自签证书；域名仅允许字母数字与 . -，同名将覆盖原配置。
壁垒WAF
bileiwaf.com
壁垒WAF
BILEIWAF CONSOLE
监控大屏
攻击日志
站点管理
证书管理
规则文件
端口配置
站点管理
已接入站点 config/sites/*.conf
刷新
配置文件 域名 后端 状态 操作
demo.local.conf demo.local 127.0.0.1:9000 启用 删除
demo.bileiwaf.com.conf demo.bileiwaf.com 127.0.0.1:9002 启用 删除
qerp.com.cn.conf qerp.com.cn 127.0.0.1:9004 启用 删除
ourshijie.com.conf ourshijie.com 127.0.0.1:9001 启用 删除
dbmon.cn.conf dbmon.cn 127.0.0.1:9005 启用 删除
bileiwaf.com.conf bileiwaf.com 127.0.0.1:9003 启用 删除
站点保存后需重载/重启 WAF 生效；删除前请确认业务已迁移。
新增 / 更新站点
保护域名 www.example.com
后端地址 127.0.0.1
后端端口 9000
文档根目录 share
启用 HTTPS 自动生成自签证书
证书有效期 365
保存站点并生成证书
保存后自动写入完整站点配置（site/ssl/logging/gzip/cache/security）并签发自签证书；域名仅允许字母数字与 . -，同名将覆盖原配置。


壁垒WAF
bileiwaf.com
壁垒WAF
BILEIWAF CONSOLE
管理菜单
监控大屏
攻击日志
站点管理
证书管理
规则文件
端口配置
当前用户 admin 管理员
修改密码
退出
© 2026 内蒙古勤加软件有限公司
壁垒WAF BILEIWAF v1.0.5
证书管理
证书列表 站点引用 + WAF_HOME/certs/ 物理证书
刷新
站点/CN
颁发者
到期日
剩余
状态
来源
demo.bileiwaf.com
demo.bileiwaf.com
C=US, O=Let's Encrypt, CN=YR2
Jan 12 01:38:00 2027 GMT
81 天
正常
站点
qerp.com.cn
qerp.com.cn
C=US, O=Let's Encrypt, CN=YR1
Jan 10 02:54:44 2027 GMT
79 天
正常
站点
ourshijie.com
ourshijie.com
C=US, O=Let's Encrypt, CN=YR1
Jan 10 02:55:46 2027 GMT
79 天
正常
站点
dbmon.cn www.dbmon.cn
dbmon.cn
C=US, O=Let's Encrypt, CN=YR1
Jan 10 02:55:16 2027 GMT
79 天
正常
站点
bileiwaf.com www.bileiwaf.com
bileiwaf.com
C=US, O=Let's Encrypt, CN=YR1
Jan 10 03:11:23 2027 GMT
79 天
正常
站点
「站点」为站点配置 cert_file 动态解析；「存储」为 WAF_HOME/certs/ 下物理证书。改动证书后需重载/重启 WAF 生效。
上传证书
保护域名
www.example.com
证书 PEM
-----BEGIN CERTIFICATE-----
-----END CERTIFICATE-----
私钥 PEM
-----BEGIN PRIVATE KEY-----
-----END PRIVATE KEY-----
应用到站点
写入站点配置（cert_file/key_file
校验并上传
上传前自动校验证书与私钥匹配（modulus 比对），不匹配直接拒绝。
证书续期 手动 / 后台每日自动
仅续期域名
留空=续期全部站点证书
立即续期
全部续期
Let's Encrypt 证书走 certbot（webroot）自动续期；自签证书用原 CN 重签。后台线程每日检查临近到期（≤30 天）证书并自动续期，成功后热加载 SSL 上下文，无需重启。
生成自签证书
保护域名
test.local
有效期（天）
365
应用到站点
写入站点配置
生成自签证书
自签证书带 SAN 扩展，仅供测试环境使用；浏览器访问需手动信任。

1,087 条检测规则分文件管理：SQL 注入 297 / 命令注入 403 / SSRF 181 等



监听端口 / 后端 / 检测模式（rules · ai · auto）在线配置，重启即生效



开源赋能行业创新 · 方案驱动场景落地

壁垒WAF BILEI WAF — 反代代理架构 · 规则 + AI 双通道检测 · 全流量可视化

壁垒防火墙官网： bileiwaf.com

内蒙古勤加软件有限公司 · 2026 年10月

致谢

2026 开源行业解决方案创新赛 组委会